



WPSCAN REPORT

Honeypot deployment



DECEMBER 21, 2025

Abstract

This report reviews security issues in a WordPress blog deployed in a controlled virtual honeypot using WPScan. Findings include outdated core and themes, exposed interfaces, configuration weaknesses, and user enumeration, all of which affect confidentiality, integrity, and availability (CIA). Mitigations encompass updates, access restrictions, login protections, the deployment of a Web Application Firewall (WAF), and Secure Sockets Layer (SSL)/Transport Layer Security (TLS) encryption, as well as automated scans.

Table of Contents

Introduction.....	1
Identified Vulnerabilities	2
Identified Security Fixes.....	4
Conclusions.....	6
References.....	7
Appendices.....	8

Introduction

WordPress is among the most widely used content management systems globally, powering over 40% of websites (Ekstam Ljusegren, 2023; Yi, Kyaw and Thandar, 2024), making it an attractive target for attackers exploiting misconfigurations, outdated software, and weak authentication mechanisms (Bose and James, 2025; Shakeel *et al.*, 2025). To examine such issues in a realistic environment, a WordPress honeypot blog was deployed in the Cyber Zone, providing a controlled platform to assess security weaknesses.

The primary objective of this report is to identify vulnerabilities using WPScan, evaluate their potential impact on confidentiality, integrity, and availability (CIA triad), and propose mitigations without directly applying patches.

Identified Vulnerabilities

The WPScan assessment (Appendix A) revealed multiple vulnerabilities in the WordPress installation, themes, and configuration.

i. WordPress Core Vulnerabilities

- Version 6.5 is outdated and has shown six known vulnerabilities (Appendix B, Figures 2–4), including:
 - Unauthenticated stored Cross-Site Scripting (XSS)
 - Contributor-level stored XSS
 - Path traversal
 - Sensitive data disclosure

Impact on CIA triad

XSS (Unauthenticated and Contributor-Level):

These vulnerabilities compromise the confidentiality and integrity of a WordPress blog, enabling session theft and content manipulation.

Path Traversal and Sensitive Data Disclosure:

These vulnerabilities breach confidentiality, exposing server and configuration data, like database credentials and user information.

ii. Theme

The scan report shows the themes twentytwentyfour, twentytwentythree, twentytwentytwo, which are outdated, and directory listing is also enabled for all themes (Appendix B, Figures 5–7).

Impact on CIA triad

Outdated themes and enabled directory listings compromise confidentiality and integrity by exposing files and structures, thereby expanding the attack surface.

iii. Configuration Weaknesses

The report shows that XML-RPC and external WP-Cron are enabled along with readme file exposure (Appendix B, Figure 1).

Impact on CIA triad

XML-RPC and WP-Cron affect availability, enabling brute-force and Denial of Service (DoS) attacks, whereas exposed readme files reveal sensitive information, compromising confidentiality.

iv. User Enumeration

WPScan identified admin accounts (Admin and admin) through RSS feeds and login error messages (Appendix B, Figures 8–9).

Impact on CIA triad:

Disclosure of administrator usernames compromises confidentiality, increasing the risk of brute-force attacks and potential unauthorized access.

Identified Security Fixes

i. Updating WordPress Core and Themes

Fix: Upgrading WordPress core to $\geq 6.8.3$ and all themes to the latest versions mitigate XSS, path traversal, and sensitive data disclosure vulnerabilities (Bose and James, 2025).

Impact: If WordPress core and themes remain outdated, known vulnerabilities can be exploited. This may result in unauthorized access, content manipulation, or malware injection.

ii. Disabling XML-RPC and WP-Cron

Fix: Disabling XML-RPC if unused prevents brute-force amplification (Shakeel *et al.*, 2025), and restricting WP-Cron to server-side triggers only prevents DoS attacks.

Impact: Leaving these services enabled exposes the site to automated attacks and resource exhaustion, increasing the risk of service disruption and unauthorized access.

iii. Restricting Access to Sensitive Files

Fix: Removing or restricting access to readme.html and versioned files reduces reconnaissance opportunities.

Impact: Unrestricted access to the readme and versioned files provides attackers with detailed system information which facilitates targeted attacks.

iv. User Enumeration Prevention

Fix: Implementing login rate limiting, CAPTCHA, and non-standard admin usernames reduces the probability of brute-force and credential-stuffing attacks (Yi, Kyaw and Thandar, 2024).

Impact: Discoverable admin usernames ease brute-force and credential-stuffing attacks.

v. Web Application Firewall (WAF) and Transport Layer Security (TLS) Enforcement

Fix: Deploying WAF filters, monitors, and blocks malicious HTTP/S traffic (Cárdenas Rosero, Guevara Vega and Landeta-López, 2025), while enforcing Secure Sockets Layer (SSL)/TLS ensures that all data transmitted between users and the WordPress site is encrypted (Bose and James, 2025).

Impact: The absence of a WAF exposes the site to SQL injection, XSS, and credential stuffing, while the lack of enforced SSL/TLS leaves it vulnerable to eavesdropping, tampering, and man-in-the-middle attacks.

vi. Regular Vulnerability Scanning

Fix: Scheduling automated WPScan scans ensures timely identification of security weaknesses in WordPress core, themes, plugins, and configuration (Yi, Kyaw and Thandar, 2024).

Impact: If regular and automated scanning is not used, vulnerabilities can remain undetected for long periods, giving attackers ample opportunity to exploit them.

Conclusions

The WPScan assessment highlights multiple security weaknesses in the honeypot WordPress blog, including outdated core and themes, exposed interfaces, and user enumeration. These vulnerabilities impact all elements of the CIA triad and increase the risk of unauthorized access, data manipulation, and service disruption.

Implementing the recommended security measures, including updates, interface hardening, WAF/TLS deployment, and proactive monitoring, will significantly reduce the attack surface and improve overall resilience (Bose and James, 2025). Regular vulnerability assessment and proactive hardening are critical for securing WordPress sites (Shakeel *et al.*, 2025).

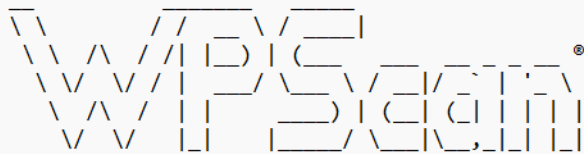
References

- Bose, E. and James, A. (2025) *Enhancing Security in Content Management Systems: Strategies for Protecting User Data and Preventing Content Tampering*, ResearchGate. Available at: https://www.researchgate.net/publication/388962816_Enhancing_Security_in_Content_Management_Systems_Strategies_for_Protecting_User_Data_and_Preventing_Content_Tampering (Accessed: 2 January 2026).
- Cárdenas Rosero, G.E., Guevara Vega, C.P. and Landeta-López, P. (2025) 'Website Protection: An Evaluation of the Web Application Firewall', *Data and Metadata*, 4. Available at: <https://doi.org/10.56294/DM2025190>.
- Ekstam Ljusegren, H. (2023) *Vulnerabilities in Outdated Content Management Systems: An Analysis of the Largest WordPress Websites*. Master's thesis. Linköping University. Available at: <https://urn.kb.se/resolve?urn=urn:nbn:se:liu:diva-202569> (Accessed: 2 January 2026).
- Shakeel, S. et al. (2025) *Analysis of Web Application Security: Integrating WAF and SSL/TLS for Enhanced CMS Protection | International Journal of Innovations in Science & Technology, IJIST*. Available at: <https://journal.50sea.com/index.php/IJIST/article/view/1612> (Accessed: 2 January 2026).
- Yi, K.M., Kyaw, L.Y. and Thandar, P. (2024) 'Enhancing Security of WordPress Websites built on Virtual Machine Using Cloud Computing Technology', *2024 5th International Conference on Advanced Information Technologies, ICAIT 2024* [Preprint]. Available at: <https://doi.org/10.1109/ICAIT65209.2024.10754914>.

Appendices

Appendix A

WPScan Full Output:



WordPress Security Scanner by the [WPScan](#) Team
Version 3.8.28
Sponsored by [Automattic](https://automattic.com/) - <https://automattic.com/>
[@_WPScan_](#), [@ethicalhack3r](#), [@erwan_lr](#), [@firefart](#)

[+] URL: <http://www.honeypot.com/wordpress/> [192.168.100.5]
[+] Started: Sun Dec 21 10:18:05 2025

Interesting Finding(s):

[+] Headers

| Interesting Entry: Server: Apache/2.4.58 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: <http://www.honeypot.com/wordpress/xmlrpc.php>

| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: <http://www.honeypot.com/wordpress/readme.html>

| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: <http://www.honeypot.com/wordpress/wp-cron.php>

| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - <https://www.iplocation.net/defend-wordpress-from-ddos>
| - <https://github.com/wpscanteam/wpscan/issues/1299>

```
[+] WordPress version 6.5 identified (Insecure, released on 2024-04-02).
| Found By: Rss Generator (Passive Detection)
| - http://www.honeypot.com/wordpress/?feed=rss2, <generator>https://wordpress.org/?v=6.5</generator>
| - http://www.honeypot.com/wordpress/?feed=comments-rss2, <generator>https://wordpress.org/?v=6.5</generator>
|
| [!] 6 vulnerabilities identified:
|
| [!] Title: WP < 6.5.2 - Unauthenticated Stored XSS
| Fixed in: 6.5.2
| References:
| - https://wpscan.com/vulnerability/1a5c5df1-57ee-4190-a336-b0266962078f
| - https://wordpress.org/news/2024/04/wordpress-6-5-2-maintenance-and-security-release/
|
| [!] Title: WordPress < 6.5.5 - Contributor+ Stored XSS in HTML API
| Fixed in: 6.5.5
| References:
| - https://wpscan.com/vulnerability/2c63f136-4c1f-4093-9a8c-5e51f19eae28
| - https://wordpress.org/news/2024/06/wordpress-6-5-5/
|
| [!] Title: WordPress < 6.5.5 - Contributor+ Stored XSS in Template-Part Block
| Fixed in: 6.5.5
| References:
| - https://wpscan.com/vulnerability/7c448f6d-4531-4757-bff0-be9e3220bbb
| - https://wordpress.org/news/2024/06/wordpress-6-5-5/
|
| [!] Title: WordPress < 6.5.5 - Contributor+ Path Traversal in Template-Part Block
| Fixed in: 6.5.5
| References:
| - https://wpscan.com/vulnerability/36232787-754a-4234-83d6-6ded5e80251c
| - https://wordpress.org/news/2024/06/wordpress-6-5-5/
|
| [!] Title: WP < 6.8.3 - Author+ DOM Stored XSS
| Fixed in: 6.5.7
| References:
| - https://wpscan.com/vulnerability/c4616b57-770f-4c40-93f8-29571c80330a
| - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-58246
| - https://patchstack.com/database/wordpress/wordpress/wordpress/vulnerability/wordpress-wordpress-wordpress-6-8-2-cross-site-scripting-xss-vulnerability
| - https://wordpress.org/news/2025/09/wordpress-6-8-3-release/
|
| [!] Title: WP < 6.8.3 - Contributor+ Sensitive Data Disclosure
| Fixed in: 6.5.7
| References:
| - https://wpscan.com/vulnerability/1e2dad30-dd95-4142-903b-4d5c580eaad2
|
| - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-58246
| - https://patchstack.com/database/wordpress/wordpress/wordpress/vulnerability/wordpress-wordpress-wordpress-6-8-2-sensitive-data-exposure-vulnerability
| - https://wordpress.org/news/2025/09/wordpress-6-8-3-release/
|
|
| WordPress theme in use: twentytwentyfour
| Location: http://www.honeypot.com/wordpress/wp-content/themes/twentytwentyfour/
| Last Updated: 2025-12-03T00:00:00.000Z
| Readme: http://www.honeypot.com/wordpress/wp-content/themes/twentytwentyfour/readme.txt
| [!] The version is out of date, the latest version is 1.4
| [!] Directory listing is enabled
| Style URL: http://www.honeypot.com/wordpress/wp-content/themes/twentytwentyfour/style.css
| Style Name: Twenty Twenty-Four
| Style URI: https://wordpress.org/themes/twentytwentyfour/
| Description: Twenty Twenty-Four is designed to be flexible, versatile and applicable to any website. Its collecti...
| Author: the WordPress team
| Author URI: https://wordpress.org
|
| Found By: UrIs In Homepage (Passive Detection)
|
| Version: 1.1 (80% confidence)
| Found By: Style (Passive Detection)
| - http://www.honeypot.com/wordpress/wp-content/themes/twentytwentyfour/style.css, Match: 'Version: 1.1'
|
|
| [i] No plugins Found.
|
| [i] Theme(s) Identified:
|
| [+] twentytwentyfour
| Location: http://www.honeypot.com/wordpress/wp-content/themes/twentytwentyfour/
| Last Updated: 2025-12-03T00:00:00.000Z
| Readme: http://www.honeypot.com/wordpress/wp-content/themes/twentytwentyfour/readme.txt
| [!] The version is out of date, the latest version is 1.4
| [!] Directory listing is enabled
| Style URL: http://www.honeypot.com/wordpress/wp-content/themes/twentytwentyfour/style.css
| Style Name: Twenty Twenty-Four
| Style URI: https://wordpress.org/themes/twentytwentyfour/
| Description: Twenty Twenty-Four is designed to be flexible, versatile and applicable to any website. Its collecti...
| Author: the WordPress team
| Author URI: https://wordpress.org
|
| Found By: UrIs In Homepage (Passive Detection)
```

```

| Confirmed By: Known Locations (Aggressive Detection)
| - http://www.honeypot.com/wordpress/wp-content/themes/twentytwentyfour/, status: 200
|
| Version: 1.1 (80% confidence)
| Found By: Style (Passive Detection)
| - http://www.honeypot.com/wordpress/wp-content/themes/twentytwentyfour/style.css, Match: 'Version: 1.1'

[+] twentytwentythree
| Location: http://www.honeypot.com/wordpress/wp-content/themes/twentytwentythree/
| Last Updated: 2024-11-13T00:00:00.000Z
| Readme: http://www.honeypot.com/wordpress/wp-content/themes/twentytwentythree/readme.txt
| [!] The version is out of date, the latest version is 1.6
| [!] Directory listing is enabled
| Style URL: http://www.honeypot.com/wordpress/wp-content/themes/twentytwentythree/style.css
| Style Name: Twenty Twenty-Three
| Style URI: https://wordpress.org/themes/twentytwentythree
| Description: Twenty Twenty-Three is designed to take advantage of the new design tools introduced in WordPress 6...
| Author: the WordPress team
| Author URI: https://wordpress.org
|
| Found By: Known Locations (Aggressive Detection)
| - http://www.honeypot.com/wordpress/wp-content/themes/twentytwentythree/, status: 200
|
| Version: 1.4 (80% confidence)
| Found By: Style (Passive Detection)
| - http://www.honeypot.com/wordpress/wp-content/themes/twentytwentythree/style.css, Match: 'Version: 1.4'

[+] twentytwentytwo
| Location: http://www.honeypot.com/wordpress/wp-content/themes/twentytwentytwo/
| Last Updated: 2025-12-03T00:00:00.000Z
| Readme: http://www.honeypot.com/wordpress/wp-content/themes/twentytwentytwo/readme.txt
| [!] The version is out of date, the latest version is 2.1
| Style URL: http://www.honeypot.com/wordpress/wp-content/themes/twentytwentytwo/style.css
| Style Name: Twenty Twenty-Two
| Style URI: https://wordpress.org/themes/twentytwentytwo/
| Description: Built on a solidly designed foundation, Twenty Twenty-Two embraces the idea that everyone deserves a...
| Author: the WordPress team
| Author URI: https://wordpress.org/
|
| Found By: Known Locations (Aggressive Detection)
| - http://www.honeypot.com/wordpress/wp-content/themes/twentytwentytwo/, status: 200

```

```
| Version: 1.7 (80% confidence)
| Found By: Style (Passive Detection)
| - http://www.honeypot.com/wordpress/wp-content/themes/twentytwentytwo/style.css, Match: 'Version: 1.7'
```

[i] No Config Backups Found.

[i] No DB Exports Found.

[i] User(s) Identified:

```
[+] Admin
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
| Rss Generator (Passive Detection)
| Login Error Messages (Aggressive Detection)

[+] admin
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)
```

```
[+] WPScan DB API OK
| Plan: free
| Requests Done (during the scan): 4
| Requests Remaining: 17
```

```
[+] Finished: Sun Dec 21 10:18:55 2025
[+] Requests Done: 31324
[+] Cached Requests: 18
[+] Data Sent: 9.951 MB
[+] Data Received: 4.559 MB
[+] Memory used: 307.223 MB
[+] Elapsed time: 00:00:50
```

Appendix B

Screenshots of Key Findings

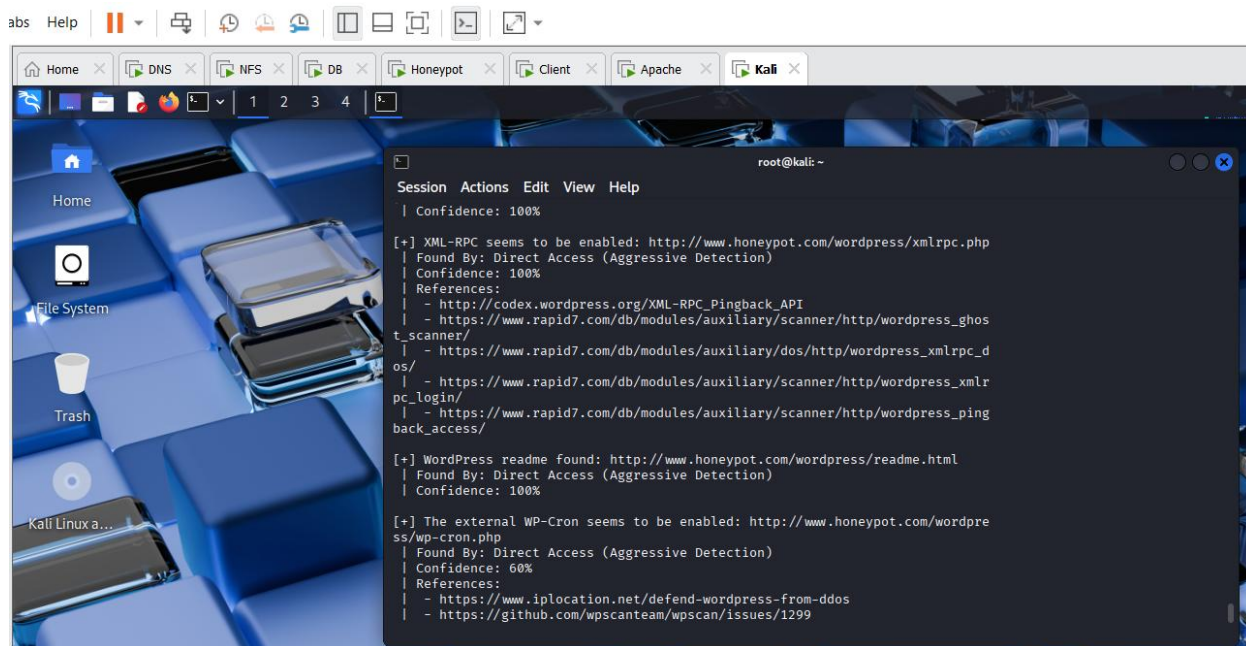


Figure: 1

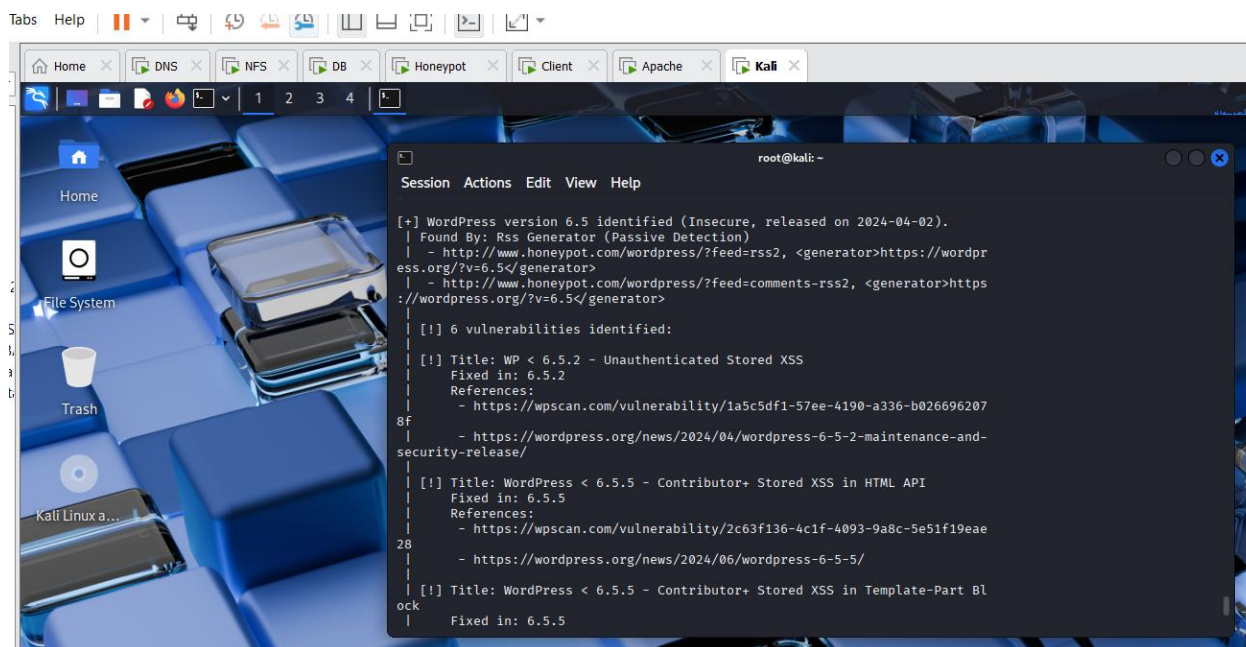


Figure: 2

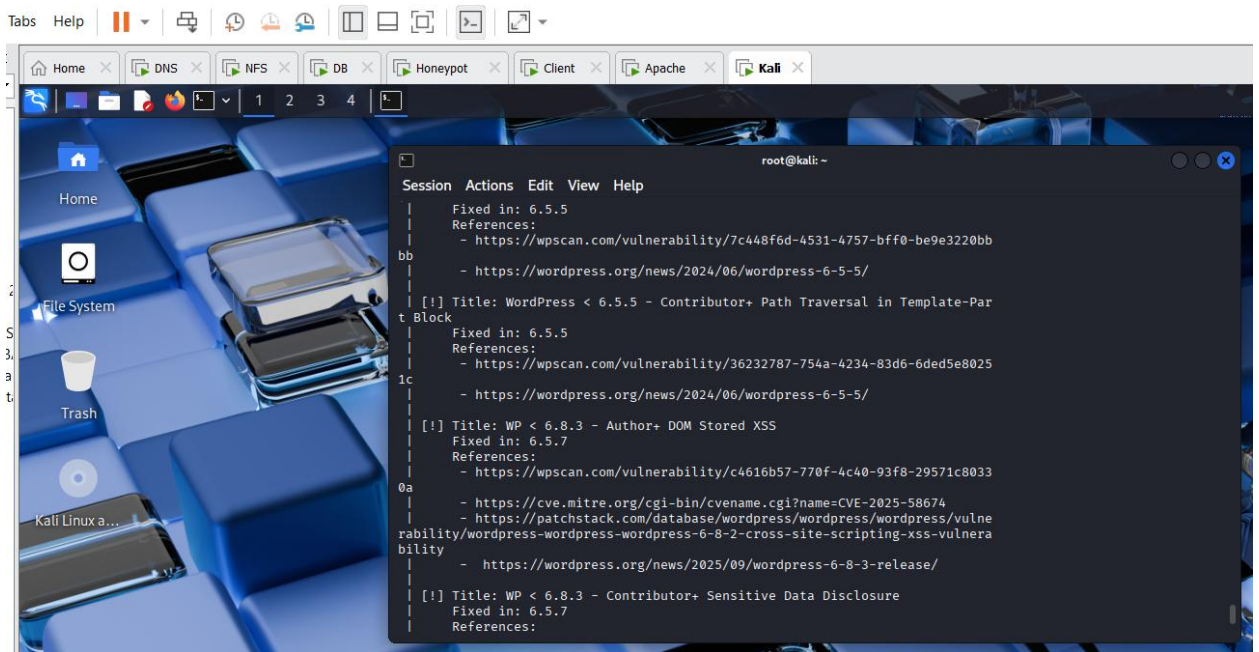


Figure: 3

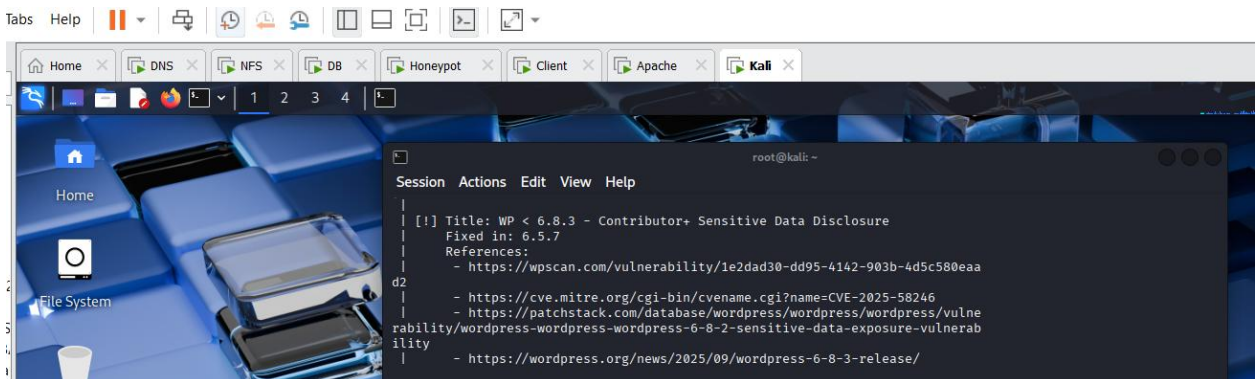


Figure: 4

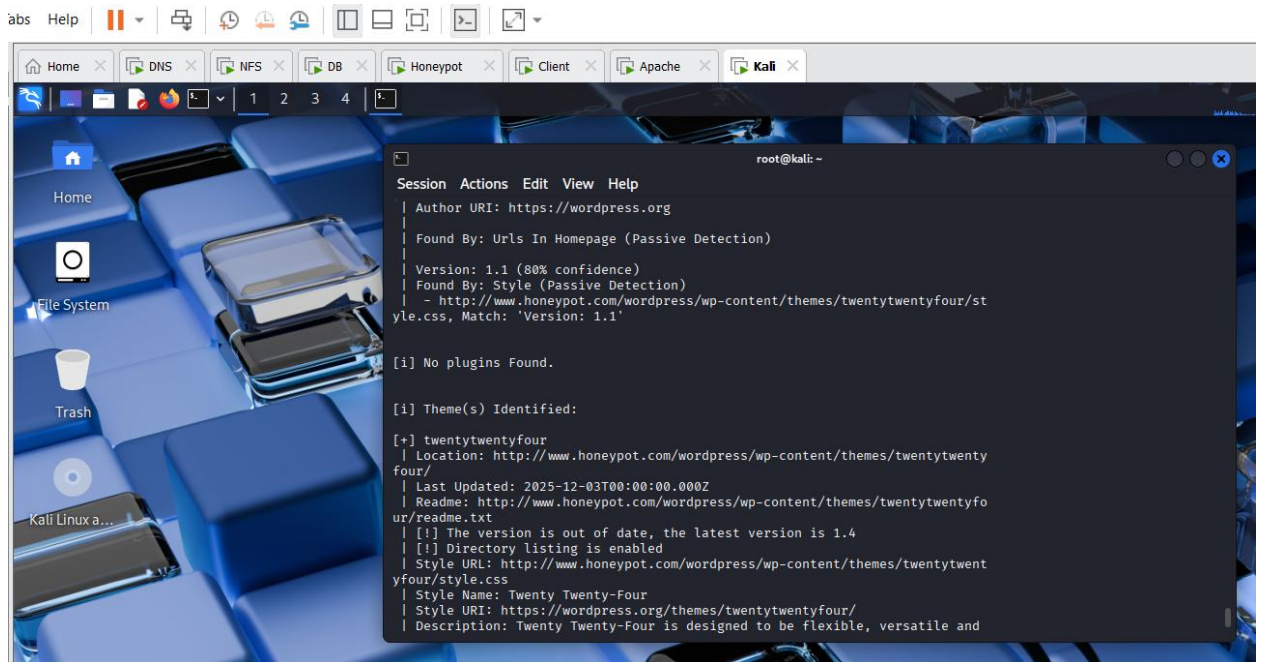


Figure: 5

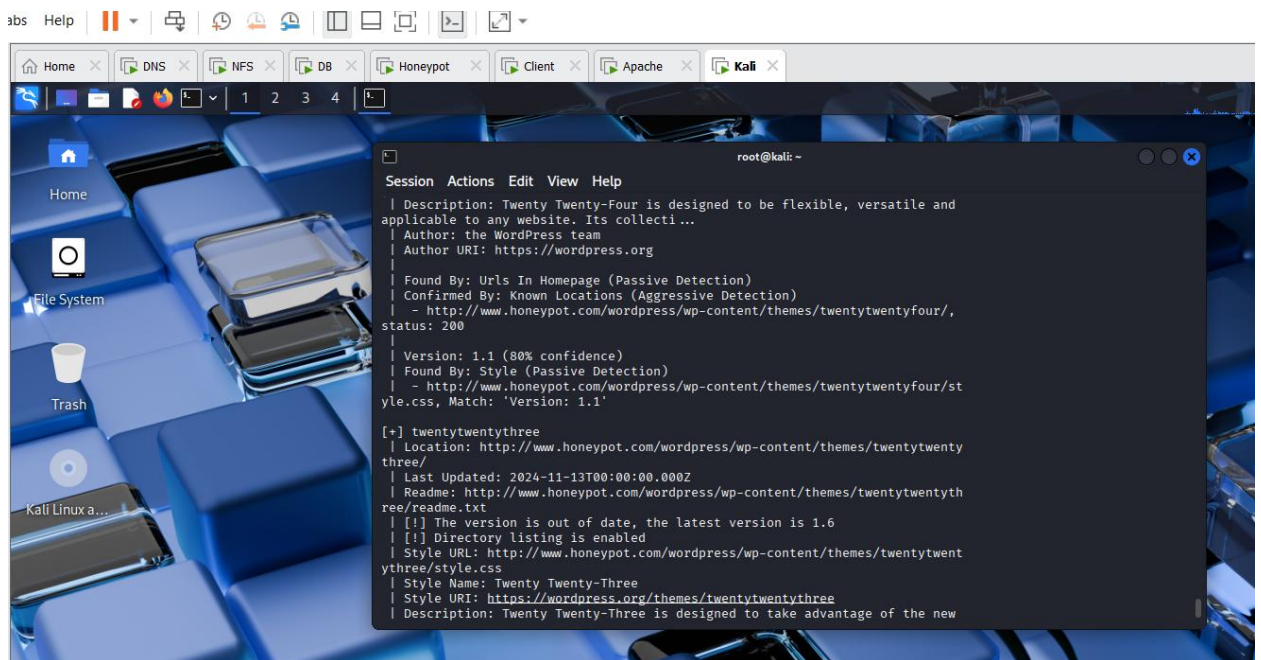


Figure: 6

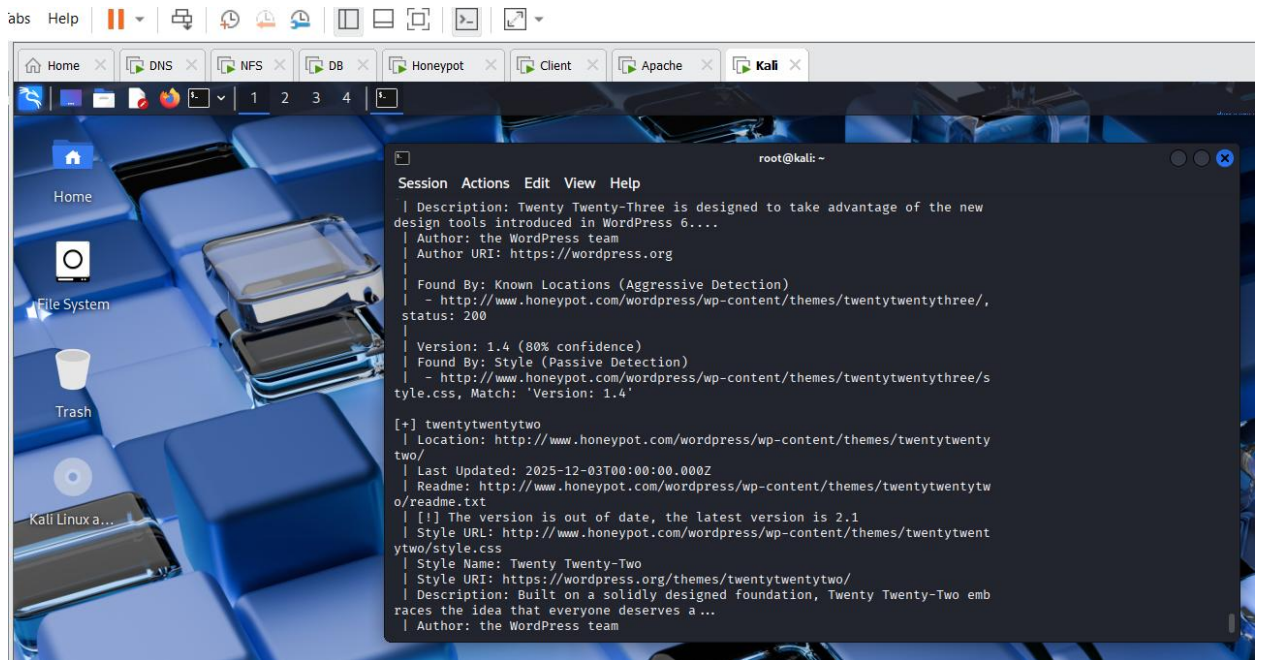


Figure: 7

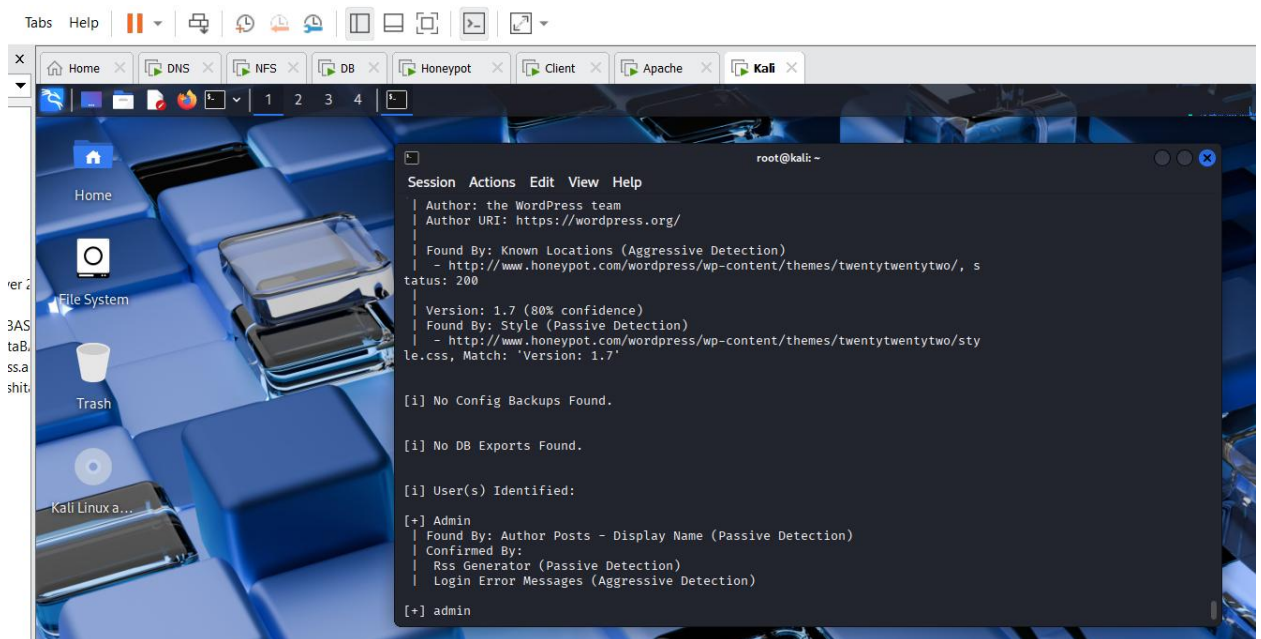


Figure: 8

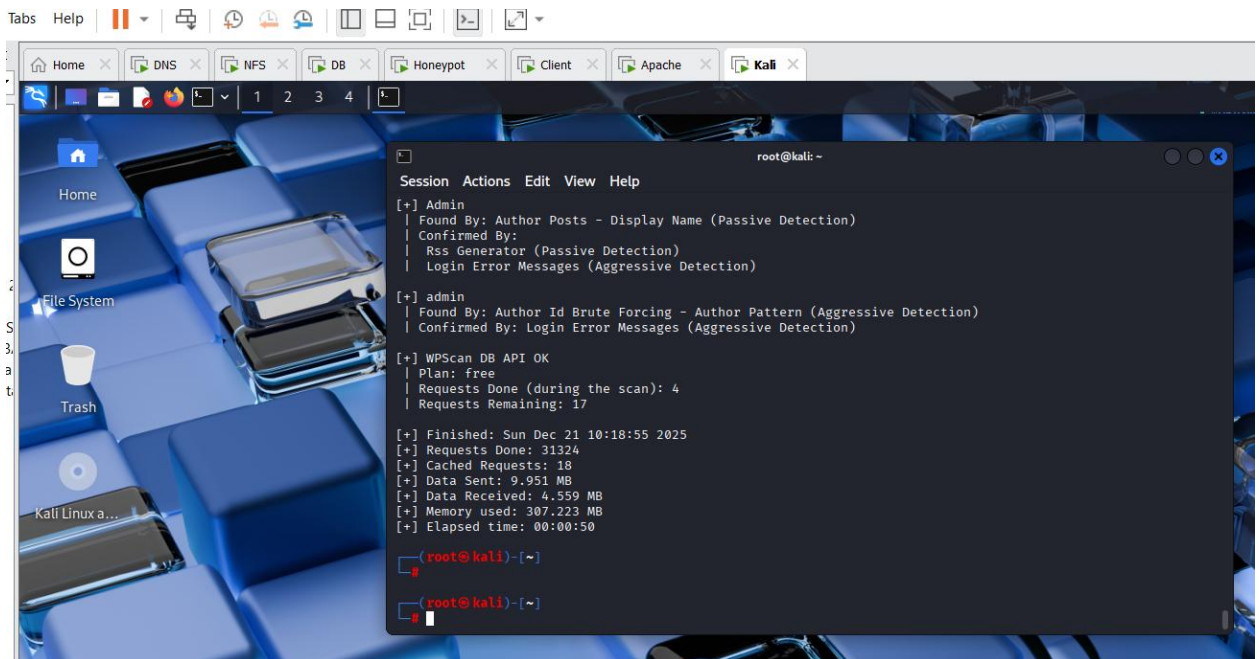


Figure: 9